Cloud Shared Responsibility and Compliance Report

Name: Innocent Utu
Date: 21/6/2026

1. Shared Responsibility Analysis

Component	Cloud Provider Responsibility	Healthcare Organization Responsibility
Data Encryption	Encrypt data at rest on cloud storage and provide encryption services	Manage encryption keys securely and ensure backups containing PHI are encrypted
Access Control	Provide Identity and Access Management (IAM) tools and authentication services	Enforce MFA, manage user accounts, perform access reviews, and deactivate unused accounts
Monitoring and Incident Response	Maintain cloud-native monitoring and logging tools	Review logs, investigate incidents, maintain incident response plans, and respond to security events
Network Security	Secure physical network infrastructure and cloud networking services	Configure firewalls, restrict administrative access, and implement network segmentation
Backup and Recovery	Provide backup and recovery capabilities and storage services	Encrypt backups, test recovery procedures, and maintain disaster recovery plans

2. Cloud Security Architecture Evaluation

Best Practice	Implemented (Yes/No/Partially)	Notes (Gap/Importance)
Data encryption at rest and in transit	Partially	Cloud data is encrypted at rest and in transit, but cloud backups are not encrypted, creating a risk of PHI exposure.
Centralized key management	No	Different key management systems are used for cloud and on-premises environments. Centralized management improves control, auditing, and key rotation.

Multi-factor authentication (MFA)	No	MFA is not mentioned in the environment. Lack of MFA increases the risk of unauthorized access through stolen credentials.
Principle of least privilege	Partially	User roles are manually managed and there are no periodic access reviews or account deactivation procedures.
Automated monitoring, logging, alerting	Partially	Monitoring tools exist but logs are not centralized across the hybrid environment, limiting visibility and incident detection.
Network segmentation	Partially	Sensitive systems are separated, but internet-facing administrative access and outdated firewalls create security risks.
Regular vulnerability assessments	No	No evidence of vulnerability assessments. Unidentified vulnerabilities may remain exploitable.
Documented and tested disaster recovery plans	Partially	Backups exist, but disaster recovery and incident response plans do not adequately address hybrid cloud risks.

3. HIPAA Compliance Comparison

HIPAA Requirement	Current Practice	Gap or Improvement Needed
Administrative Safeguards	User roles are managed manually and incident response plans exist	Implement MFA, perform regular access reviews, establish account deactivation procedures, and update incident response plans for hybrid cloud environments.
Physical Safeguards	Cloud provider secures physical data centers and infrastructure	No significant gap identified; continue reviewing provider compliance certifications.
Technical Safeguards	Data is encrypted in transit and cloud data is encrypted at rest	Encrypt backups, implement centralized key management, centralize logging, and conduct regular vulnerability assessments.

4. Recommendations for Improvement

Summary of Recommendations:

1. Implement Multi-Factor Authentication (MFA) for all user and administrator accounts to reduce the risk of unauthorized access and strengthen HIPAA compliance.
2. Encrypt all cloud backups containing Protected Health Information (PHI) to prevent exposure of sensitive healthcare data.
3. Centralize key management across cloud and on-premises environments to improve encryption key control, auditing, and compliance management.
4. Conduct regular access reviews and establish automated account deactivation processes to support the principle of least privilege.
5. Implement a centralized logging and monitoring solution (SIEM) to improve visibility across the hybrid environment and accelerate incident detection.
6. Upgrade outdated firewalls and enable advanced security features such as intrusion prevention and deep packet inspection.
7. Perform regular vulnerability assessments and penetration testing to identify and remediate security weaknesses before they can be exploited.
8. Update and test disaster recovery and incident response plans to address hybrid cloud-specific threats and ensure business continuity.

Conclusion:

The organization has implemented several important security controls, including encryption of cloud-hosted data and use of cloud-provider security services. However, significant gaps remain in backup encryption, MFA, centralized key management, access governance, vulnerability management, and monitoring. Addressing these issues will strengthen the organization's security posture, improve protection of PHI, and enhance compliance with HIPAA requirements.